EXECUTIVE REPORT

# AI Governance & Regulatory Readiness

An executive assessment of the Organization's AI governance posture against ISO/IEC 42001:2023, the NIST AI Risk Management Framework, and the EU AI Act — with the priorities leadership must act on.

*Client identity, systems and figures have been anonymized for confidentiality. Prepared for executive and board-level review.*

| PREPARED FOR | CLIENT | FRAMEWORKS | PREPARED BY |
|---|---|---|---|
| Executive Leadership | Anonymized | ISO/IEC 42001 · NIST AI RMF · EU AI Act | Fabricio Goveia · GRC |
| DATE | CLASSIFICATION | | |
| October 2026 | Confidential | | |

**49%**

**AI governance maturity: Emerging.** AI is central to the business, but governance has not kept pace. The Organization carries regulatory exposure on a high-risk AI system and lacks the formal management system auditors and regulators expect.

## 01 Executive summary

The Organization is innovating quickly with AI, but its governance and compliance posture lags its technical ambition — creating regulatory, reputational and operational risk that now requires leadership attention.

This assessment measured the AI governance posture against three reference frameworks: ISO/IEC 42001:2023 (AI Management System), the NIST AI Risk Management Framework, and the EU AI Act. It covered the management system, the AI system lifecycle, and a regulatory risk-tier classification of AI systems in use.

The central finding is a **gap between AI adoption and AI control**. A customer-facing decisioning model qualifies as high-risk under the EU AI Act, yet operates without the risk management system, technical documentation and human oversight the regulation requires. More broadly, AI risk is managed informally, with no documented methodology

and no AI management system to provide assurance to customers, partners and regulators.

None of the gaps are structurally difficult to close. With focused effort over roughly two quarters, the Organization can remove its most material regulatory exposure and reach certification and conformity readiness.

| 6 | 1 | 49% | ~6 mo |
|---|---|---|---|
| Priority actions | High-risk AI system | Maturity | To readiness |

## 02 Governance posture

Maturity was scored 0–5 across the three frameworks. The picture is consistent: governance intent exists, but the operational controls and documentation that make it auditable are largely absent.

### ISO/IEC 42001 — MANAGEMENT SYSTEM

| | |
|---|---|
| Context & AI policy | 3 |
| Planning & AI risk | 1 |
| Operation & lifecycle | 2 |
| Evaluation & improvement | 1 |

### NIST AI RMF — FUNCTIONS

| | |
|---|---|
| Govern | 2 |
| Map | 1 |
| Measure | 1 |
| Manage | 2 |

### EU AI ACT — HIGH-RISK OBLIGATIONS

| | |
|---|---|
| Risk management & data governance | 1 |
| Technical documentation & records | 0 |
| Transparency & human oversight | 1 |

0 None 1 Initial 2 Partial 3 Defined 4 Managed 5 Optimized

## 03 Priority actions

The six priority actions, framed for decision-making. Each states the exposure it removes.

PRIORITY 1 — EU AI Act Art. 9–15

### Bring the high-risk AI system into conformity

The customer-facing decisioning model is high-risk under the EU AI Act but lacks a risk management system, technical documentation, record-keeping and human oversight.

**Removes:** the Organization's most material regulatory exposure and a barrier to EU market access.

PRIORITY 2 — ISO 42001 Cl.6 · NIST Map/Measure

### Establish a formal AI risk management process

Introduce a documented AI risk methodology and register covering bias, accuracy, misuse and data quality across the AI lifecycle, with measurable metrics.

**Removes:** reliance on informal judgement; creates the assurance backbone for every other control.

PRIORITY 3 — ISO 42001 A.5

### Introduce AI system impact assessments

Assess impacts on individuals and groups (fairness, safety, rights) before deployment and at material change.

**Removes:** blind spots on harm and the reputational risk of unassessed outcomes.

PRIORITY 4 — ISO 42001 A.10

### Extend vendor risk to AI providers

Apply AI-specific due diligence and contractual requirements to third-party models and data providers.

**Removes:** inherited risk from the AI supply chain, with responsibility clearly allocated.

PRIORITY 5 — ISO 42001 A.2 · NIST Govern

### Formalize AI policy and accountability

Approve an AI policy and assign clear governance roles and decision rights across data science, product and legal.

**Removes:** ambiguity over who owns AI risk decisions.

PRIORITY 6 EU AI Act Art. 13

### Strengthen transparency to users

Ensure users are appropriately informed where they interact with, or are subject to, AI-driven decisions.

**Removes:** a transparency gap that regulators and customers increasingly scrutinize.

## 04 Roadmap

A phased plan that front-loads the legal exposure, then builds the management system toward certification and conformity readiness.

| | | |
|---|---|---|
| Q1 · M1–2 | **Foundations** | AI system inventory, EU AI Act risk tiering, AI risk methodology and register, AI policy. |
| Q1–Q2 · M2–4 | **High-risk conformity** | Technical documentation, human oversight, logging and impact assessment for the high-risk system. |
| Q2 · M4–5 | **Management system** | Data governance, AI vendor requirements, performance/bias metrics, roles and accountability. |
| Q2–Q3 · M5–7 | **Assurance** | Internal audit, management review, and readiness for ISO 42001 certification and EU AI Act conformity. |

## 05 Recommendation

Treat the high-risk AI system as the immediate priority and stand up a formal AI risk process in parallel.

These two actions remove the bulk of the Organization's regulatory exposure and create the foundation everything else builds on. The remaining priorities can then be sequenced over the following quarter without disrupting delivery. The Organization is well positioned: the talent and the AI capability are already in place — what is missing is the governance layer that makes them defensible.

**Note.** This report is a confidential executive assessment. Client identity, systems and figures have been anonymized. It is not legal advice; EU AI Act obligations should be confirmed with qualified counsel. Frameworks referenced: ISO/IEC 42001:2023, ISO/IEC 23894, NIST AI RMF 1.0, EU AI Act.